

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 3 Practical Laboratory

Roles, Responsibilities and Accountability in Security Governance

TechGlobal Governance Transformation Simulation

Name	Adeshola Oluwole
Registration Number	C1126CGRCE17211
Course	GRC102 – Information Security Governance
Module	Module 3 – Roles and Responsibilities in Security Governance
Week	Week 3: 19–25 September 2026
Opens	19 September 2026, 8:00 AM WAT
Due	25 September 2026, 11:59 PM WAT
Maximum Score	100 marks
Effective Course Contribution	10% – Practical Laboratories

Submission mode: Written report + supporting evidence

Scenario-based governance laboratory • No production-system access is required

1. Laboratory Overview

TechGlobal is a fast-growing technology organisation with approximately 2,500 employees across five global offices. Revenue and product adoption are increasing, but its security governance model has not matured at the same pace. Most security decisions are still concentrated with the IT Director, there is no formal governance committee structure, business units operate inconsistently, and the CEO and Board receive limited visibility into cyber risk.

You have been appointed Lead Security Governance Consultant. Your task is to redesign TechGlobal's governance model so that security decisions are business-aligned, accountabilities are clear, conflicts are resolved appropriately, and material cyber risks can be escalated from operational teams to executive management and the Board.

2. Learning Objectives

- Analyse weaknesses created by informal, IT-centric security governance.
- Design a scalable governance structure linking Board oversight, executive leadership, security management and business units.
- Define clear responsibilities and decision authority for the Board, CEO, CISO, CRO/Risk, Legal, Finance, HR and IT.
- Design an effective cross-functional Security Governance Committee structure.
- Apply a RACI model to eliminate ambiguity and improve accountability.
- Design a material cyber-risk escalation workflow and decision trail.
- Identify segregation-of-duties conflicts and recommend practical corrective controls.

3. Scenario and Stakeholder Context

TechGlobal's current model can be described as "security by informal decision." The IT Director is effectively acting as security owner, risk approver and operational decision-maker. Business-unit leaders make local security choices, and there are no formal committees or reliable escalation paths. This creates concentration of authority, inconsistent control ownership, weak oversight and limited Board visibility.

Stakeholder	Governance Role	Primary Concerns
Board of Directors	Oversight and risk appetite	Regulatory exposure, brand reputation, material risk, assurance and accountability.
CEO	Executive accountability	Growth, strategic alignment, acceptable risk and business performance.
CISO	Security governance leadership	Security strategy, policy, risk oversight, reporting and programme effectiveness.
CRO / Risk	Enterprise risk integration	Risk methodology, risk acceptance, treatment and

Stakeholder	Governance Role	Primary Concerns
		enterprise aggregation.
Legal / Compliance	Legal and regulatory advice	Regulatory duties, contractual obligations, privacy, evidence and notification.
Finance	Financial governance	Budget, loss exposure, investment prioritisation and financial controls.
Human Resources	People governance	Joiner/mover/leaver controls, awareness, conduct and disciplinary processes.
IT / Technology	Technology delivery	Secure operation, implementation, technical control ownership and service continuity.
Business Unit Leaders	Business ownership	Operational performance, local risk decisions and control implementation.

4. Task 1 Governance Architecture and Stakeholder Map (20 marks)

The Board has asked you to replace the current informal model with a governance structure that connects operational security decisions to executive and Board oversight.

- Identify at least five weaknesses in the current governance model and explain the business or risk consequence of each.
- Create a stakeholder map showing the interests, authority, information needs and expected contribution of the Board, CEO, CISO, CRO/Risk, Legal, Finance, HR, IT and Business Units.
- Design a Security Governance Organisation Chart showing reporting lines, oversight relationships and communication paths.
- Explain why the proposed structure is appropriate for a 2,500-employee technology organisation operating across five offices.

Required Evidence Task 1

- Governance gap assessment.
- Stakeholder map.
- Security Governance Organisation Chart.
- 1–2 page consultant justification.

4.1 FIVE (5) Weaknesses and Business Risk Consequences in the Current Model Governance Model

The below are weaknesses in the current governance model at TechGlobal:

- 1) The concentration of Authority is in the hands of the IT Director
- 2) There is no formal structure of the governance committee
- 3) The business unit security decision making process is not consistent
- 4) There is no trustworthy escalation path from the operations department to the executives
- 5) The CEO and the Board have limited visibility into cyber risk governance

The business risk consequences of the above governance gap assessment at Tech Global include:

- 1) There is no independent check on any security decision — the same person who implements a control also decides whether the leftover risk is acceptable. This is a failure in the segregation-of-duties that would not pass an external audit, and it means TechGlobal's entire security posture depends on the IT Director's judgment and availability.
- 2) Legal, Finance, and HR implications of security decisions only come to light after decisions are already made, instead of being considered upfront — for example, a data-handling decision made on purely technical grounds could create regulatory exposure that no one flagged in time.
- 3) Different offices end up with different levels of security and all these problems pile up with no way to see the entire picture which does not make the Board get a straight answer to the level of risk TechGlobal is at any given point in time.
- 4) A serious incident could get stuck at the operational level and past the deadline for regulatory reporting thereby turning an incident that could have been managed into a compliance violation.
- 5) The Board cannot properly oversee risk and cannot set a clear limit for how much risk it is willing to accept, and security spending has no risk basis that the Board has actually approved .

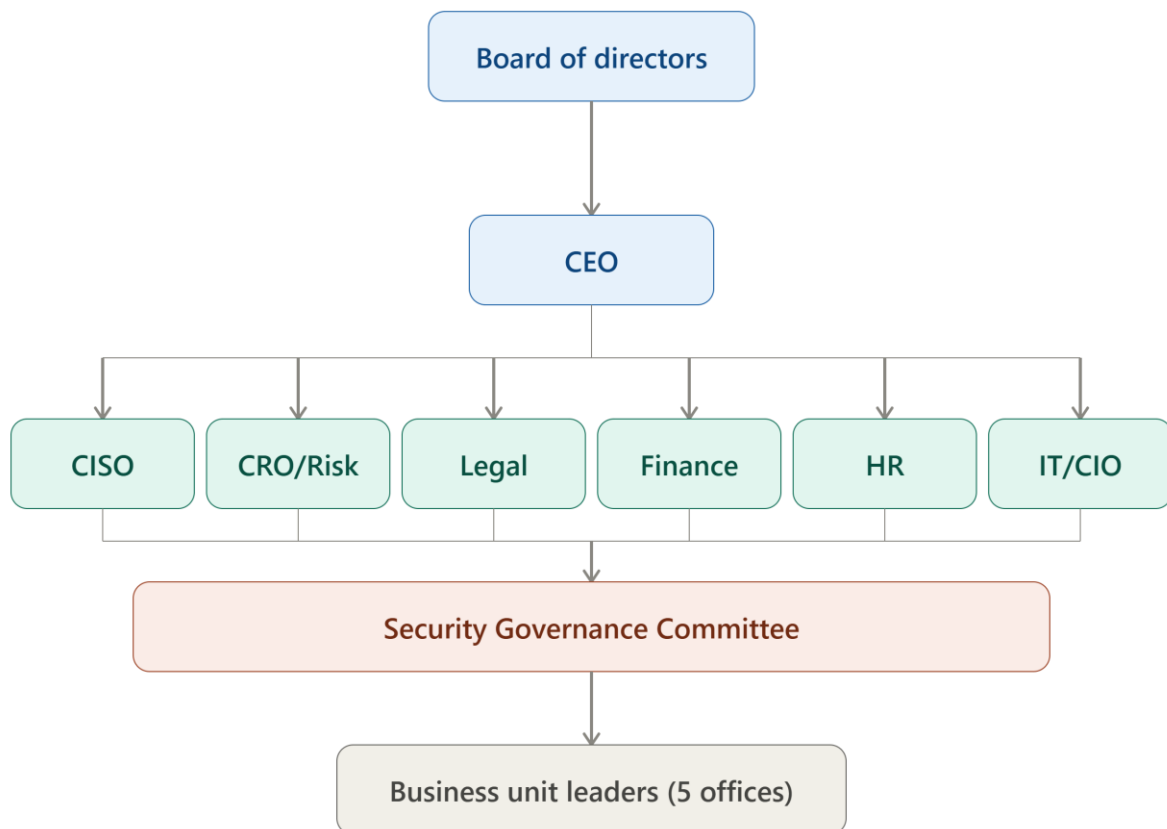
4.2 Stakeholder Map

Below is a stakeholder map designed to show the interests, authority, information needs and expected contribution of the Board, CEO, CISO, CRO/Risk, Legal, Finance, HR, IT and Business Units for GlobalTech

Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution
The Board	Ultimate oversight; sets risk appetite; final risk acceptance for material risk	Regulatory exposure, brand reputation, fiduciary duty	Quarterly risk posture, material incident briefings, assurance reports	Approves strategy/appetite, holds executives accountable
The CEO	Approves governance structure, resourcing, crisis leadership	Growth, strategic alignment, business performance	Program effectiveness, risk trends, incident summaries	Translates Board direction into execution; owns crisis governance
The CISO (to be created)	Owns security strategy, policy, architecture standards	Program effectiveness, risk visibility, credibility with Board	Incident data, control gaps, threat landscape	Leads governance committee; reports risk posture upward
The CRO / Risk (to be created)	Sets risk methodology; approves enterprise risk acceptance thresholds	Enterprise-wide risk consistency	Aggregated risk data across all functions, not just IT	Provides independent challenge to CISO's risk assessments
Legal / Compliance	Determines regulatory obligations, notification timing	Regulatory duties, privacy, litigation exposure	Incident facts, jurisdictional exposure (5 offices = multiple regimes)	Gatekeeper for external disclosure and legal risk
Finance	Approves budget, quantifies loss exposure	Investment prioritisation, financial control	Cost of incidents, budget requests with risk justification	Validates spend is proportionate to risk
Human Resources	Approves training, disciplinary action, JML controls	Conduct, awareness, insider risk	Policy violations, access-related personnel changes	Executes people-layer controls (onboarding/offboarding)
IT / Technology	Implements controls, owns technical delivery	Service continuity, secure operation	Approved policies/standards to implement	First line of defense; executes CISO-approved controls
Business Unit	Local operational decisions, control implementation	Operational performance, local risk	Enterprise policy, risk thresholds, escalation triggers	Feed local risk visibility into governance committee

4.3 Organisational Chart

Below is an organizational chart showing how the roles connect to each other which highlights the structural gap in the 4.1 weaknesses 1) and 4) above which has concentration of authority and no escalation path.



4.4 Consultant Justification

The proposed governance structure is designed to address the main weaknesses identified in TechGlobal's current security arrangements while also making the structure easier to manage as the company develops. With around 2,500 employees across five offices, security decisions often involve several departments at the same time, including IT, Legal, Finance, HR and Risk. Having these issues go directly to the CEO would simply create another bottleneck. A single Security Governance Committee provides a central place where these functions can discuss risks, resolve disagreements and agree on actions before matters need to be escalated to the CEO or Board.

The CISO is positioned alongside Risk, Legal, Finance, HR and IT rather than being placed above or below these functions. This is important because the current structure gives the IT Director too much control over security, risk approval and operational decisions. Separating these responsibilities creates better checks and balances. Each function can provide its own view of a security issue, reducing the chance that one department makes a major security decision without sufficient challenge from others. This also improves segregation of duties and makes accountability clearer.

Business Unit Leaders are placed under the Committee rather than given separate reporting lines into it. This allows the organisation to maintain constant security decisions across different business units without making the Committee unnecessarily large or difficult to manage. Business Unit Leaders can receive guidance from the Committee while also reporting local security and business risks back through the same structure. They therefore remain involved in governance without creating separate security silos.

Finally, the CISO should have a dotted-line relationship with the Board's risk oversight function. This provides an additional escalation route when a significant security risk needs Board attention. It also means that important risks do not depend entirely on the CEO or CIO deciding whether they should be escalated.

Overall, the proposed structure creates clearer accountability, better separation of responsibilities and a more reliable escalation process. It also gives TechGlobal a governance model that can support its current size while remaining practical as the organisation continues to expand.

5. Task 2 Governance Responsibility and Authority Matrix (20 marks)

A governance chart only becomes effective when decision rights and accountabilities are explicit. Define who owns, approves, advises and executes key governance activities.

- Develop a responsibility profile for the Board, CEO, CISO, CRO/Risk, Legal, Finance, HR and IT.
- For each role, define purpose, key governance responsibilities, decision authority, reporting obligations and at least two performance indicators.
- Identify at least three areas where authority could overlap or conflict and explain how the governance model should resolve those conflicts.

Required Evidence Task 2

- Cross-functional Governance Responsibility Matrix.
- Role profiles / responsibility cards for the eight core governance roles.
- Short conflict-resolution note identifying overlapping authority and resolution principles.

5.1 & 5.2 Cross-functional Governance Responsibility Matrix

Role	Purpose	Core Responsibilities	Decision Authority	Reports / Escalates To	KPIs / Evidence
Board	Ultimate risk oversight	Set risk appetite, approve strategy and approves the final risk acceptance	Approves strategy, budgeting and risk acceptance	Shareholders and Regulators	% of material risks reviewed on time; audit findings closed
CEO	Executive accountability	Sets the structure of governance , allocates resources	Approves resourcing, organize structure, manages crisis decisions	Board	Security incidents with CEO-level response time; program maturity score
CISO	Security governance leadership	Strategy, policy, architecture standards, risk reporting	Approves policy, security architecture, control standards	CEO	SLA compliance rate; policy coverage %; time-to-detect
CRO / Risk	Enterprise risk integration	Risk methodology; risk acceptance criteria; aggregation	Approves risk acceptance thresholds; enterprise risk sign-off	CEO/Board Risk Committee	Risk register accuracy; risks aggregated across BUs
Legal	Regulatory/legal advice	Breach notification, contracts, regulatory interpretation	Approves external disclosure; notification timing	CEO	Notification deadline compliance %; regulatory findings

Finance	Financial governance	Budget approval, loss quantification, insurance	Approves security budget, insurance coverage	CEO/CFO	Budget-to-risk alignment; incident cost variance
HR	People governance	JML controls, awareness training, discipline	Approves disciplinary action, training curriculum	CEO	Training completion %; offboarding access-removal time
IT	Technology delivery	Implements controls; system operations	Approves technical implementation approach	CIO (with CISO sign-off on controls)	Patch compliance %; uptime vs. control-deferral rate

5.3 Overlap/Conflict Areas and Resolution

There are a few areas where the responsibilities of the different roles may overlap and cause disagreements. These issues need to be clearly defined so that security decisions can be made without creating confusion.

1. CISO and IT – Security controls

The CISO is responsible for deciding what security controls are needed, while the IT team is responsible for putting them in place. However, IT may sometimes want to delay a security update because it could affect system performance or business operations. If this happens, the delay should not be decided by IT alone. The reason for the delay should be recorded and the CISO should approve it for a specific period. This makes sure that security issues are not ignored because of operational pressure.

2. CISO and CRO – Risk acceptance

Another possible conflict is between the CISO and the Chief Risk Officer (CRO). The CISO should identify and explain the security risk, but the CRO should make the final decision on whether the organisation is willing to accept that risk. Keeping these roles separate is important because the person assessing the risk should not also be the person approving it. This provides a better level of accountability and reduces the possibility of one person making the entire decision.

3. Legal and CISO – Reporting security incidents

The CISO and Legal team may also have different responsibilities when a security incident occurs. The CISO will normally have the technical information about what happened, what systems were affected and the possible impact. Legal, however, should determine whether the incident needs to be reported to regulators or other parties. This means the CISO provides the facts and technical advice, while Legal makes the final decision about notification. Having this separation helps the organisation meet its legal reporting requirements on time while keeping each role within its proper responsibility.

6. Task 3 Security Governance Committee Ecosystem (20 marks)

Security governance requires formal forums where risk, investment, compliance and technology decisions can be reviewed and resolved collectively rather than by one department.

- Design an Executive Security Council for strategic oversight.
- Design a Security Governance / Steering Committee for cross-functional governance decisions.
- Define one specialised Working Group appropriate to TechGlobal (for example Incident Response, Cloud Security or Third-Party Risk).
- Define how Business Units will participate in governance without creating separate security silos.
- Show how decisions and risk information move from operational forums to executive management and, where material, to the Board.

Required Evidence Task 3

- Committee structure / interaction diagram.
- Terms of Reference for the Security Governance Committee.
- Sample committee agenda.
- Sample decision log with at least three example decision entries.
- 12-month governance calendar showing recurring governance activities and key milestones.

6.1 Executive Security Council for strategic oversight.

Security Governance Committee	Purpose	Members	Frequency	Authority
Executive Security Council (Strategic Oversight)	Sets security strategy direction, approves major investments, reviews enterprise risk posture.	CEO (chair), CISO, CRO, CFO, General Counsel, CIO.	Quarterly	Approves strategic direction and budget; escalates material items to Board.

6.2 Security Governance/ Steering Committee (Cross-functional decisions)

Security Governance Committee	Purpose	Members	Frequency	Authority
Security Governance / Steering Committee	Operational governance forum — reviews policy, resolves cross-functional risk decisions, monitors program performance.	CISO (chair), CRO, Legal, Finance, HR, IT, rotating BU representative.	Monthly	Approves policy updates, resolves SoD/authority conflicts, escalates unresolved or material items to the Executive Security Council.

6.3 Specialized Working Group

Security Governance Committee	Purpose	Members	Frequency	Authority
Incident Response	Tactical coordination during active incidents; post-incident review.	IT Security lead (chair), SOC, Legal, Communications, affected BU representative (as needed).	Ad hoc (activated on incident); standing monthly readiness review.	Executes containment/response decisions within pre-approved playbooks; escalates anything exceeding playbook authority to the Steering Committee.

6.4 Business Unit Participation

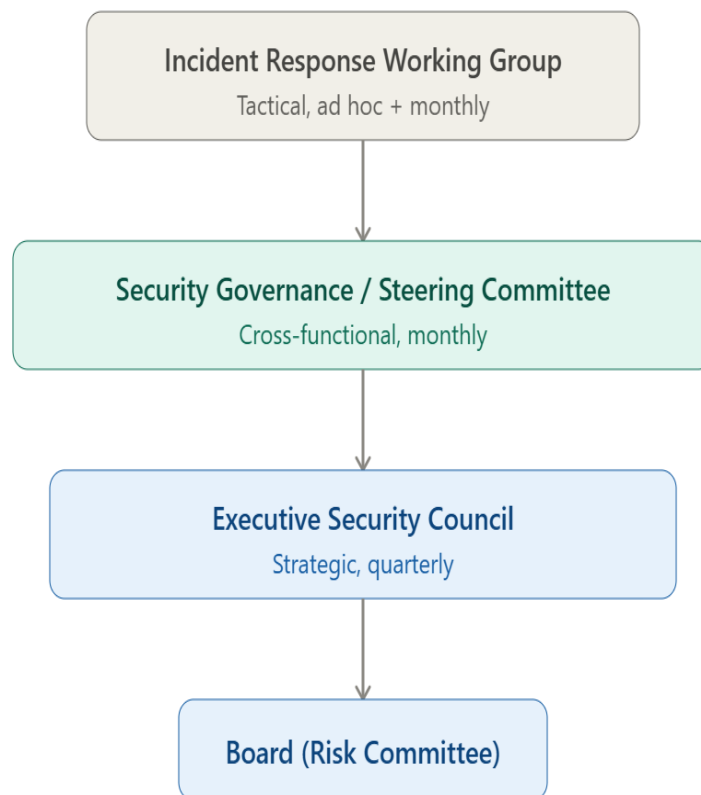
Each Business Unit (BU) should choose a Security Champion to represent them. The representatives can take turns attending the Security Steering Committee meetings. Their role would be to bring security concerns from their own business unit to the committee and also share relevant decisions with their teams.

This gives each business unit an opportunity to be heard without creating separate security structures for each one. Any security decision that could affect more than one business unit would still be handled through the main Steering Committee. This approach keeps security

governance under one structure while making sure that the needs and risks of individual business units are not overlooked.

6.5 Decision Flow (From Operational to Executive – Board)

The Working Group will handle day-to-day security incidents and issues. If an issue is considered serious or could have a wider impact, it will be escalated to the Steering Committee. The Steering Committee will deal with issues that involve different departments and, where necessary, escalate major risks or strategic matters to the Executive Security Council. The Council will provide regular updates to the Board every quarter and report immediately if there is a major security risk that requires the Board's attention.



Terms of Reference: Security Governance Committee (Brief Form)

Section	Content
Purpose	• Cross-functional review and • Approval of security policy, risk decisions, and control conflicts
Chair	CISO
Members	CRO, Legal, Finance, HR, IT, rotating BU Security Champion
Frequency	Monthly
Quorum	CISO + 4 of 6 members
Authority	• Approves policy updates; • Resolves cross-functional conflicts; • Escalates material risk to Executive Security Council
Reporting	Minutes or decision log to Executive Security Council

Sample Agenda

- ✓ Review of open decisions/actions from last meeting
- ✓ Incident summary and SLA/breach performance
- ✓ Policy items requiring approval
- ✓ Third-party/vendor risk review
- ✓ Escalation items for Executive Council

Sample Decision Log

Date	Decision / Issue	Owner	Decision	Rationale	Review Date
12-Jan-2026	MFA exception request (legacy vendor portal)	CISO	Approved for 90 days, logged as exception	Vendor system incompatible with MFA; compensating control (IP allowlist) applied	12-Apr-2026
15-Feb-2026	Third-party cloud vendor risk rating	CRO	Rated Medium-High; enhanced monitoring required	Vendor lacks SOC 2 certification	15-Aug-2026
15-Feb-2026	BU-requested exception to password policy	Committee	Denied	No compensating control offered; risk not justified by business need	N/A

12- Month Governance Calendar

Quarter	Recurring Activity
Q1	- Steering Committee monthly - Executive Council Q1 review - Annual policy review kickoff
Q2	- Steering Committee monthly - Executive Council Q2 review - Incident response tabletop exercise
Q3	- Steering Committee monthly - Executive Council Q3 review - Third-party risk reassessment
Q4	- Steering Committee monthly - Executive Council Q4 review - Annual Board briefing - Policy sign-off for following year

7. Task 4 RACI Accountability Matrix (20 marks)

When accountability is vague, incidents and decisions are delayed. Develop a RACI matrix that makes accountability visible and usable during normal operations and cyber incidents.

- Create a RACI matrix covering at least the 15 activities listed below.
- Ensure each activity has one clear Accountable role wherever practicable.
- Identify and explain at least three problematic assignments that could create confusion, conflict or weak accountability.

Minimum activities:

- Cybersecurity strategy approval
- Security policy approval
- Enterprise cyber-risk assessment
- Risk acceptance
- Security budget approval
- Security architecture approval
- Third-party security review
- Access governance
- Incident response governance
- Material incident escalation
- Regulatory notification decision

- Security awareness programme
- Vulnerability remediation oversight
- Business continuity / recovery governance
- Board cyber-risk reporting

Required Evidence Task 4

- Completed TechGlobal RACI Matrix.
- One-page implementation guide explaining how managers should use the RACI matrix during planning, approvals and incidents.

TechGlobal RACI Matrix

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU Leader
Cybersecurity strategy approval	A	C	R	C	I	I	I	I	I
Security policy approval	I	I	A/R	I	C	I	I	C	I
Enterprise cyber-risk assessment	I	I	R	A	I	I	I	C	C
Risk acceptance	I	I	C	A	C	I	I	I	I
Security budget approval	I	C	R	C	A	I	I	I	I
Security architecture approval	I	I	A	C	I	I	I	R	I
Third-party security review	I	I	R	A	C	C	I	I	C
Access governance	I	I	A	I	I	I	C	R	I
Incident response governance	I	I	A	I	C	I	I	R	C
Material incident escalation	I	A	R	C	C	I	I	I	I
Regulatory notification decision	I	C	C	I	A	I	I	I	I

Security awareness programme	I	I	R	I	I	I	A	C	I
Vulnerability remediation oversight	I	I	A	I	I	I	I	R	C
Business continuity / recovery governance	I	A	R	C	C	C	I	R	C
Board cyber-risk reporting	I	A	R	C	I	I	I	I	I

Note that for Risk Acceptance, the Board becomes A instead of the CRO the moment the risk exceeds the material risk threshold.

RACI Matrix Implementation Guide

Purpose: This guide explains how TechGlobal staff and managers should use the RACI matrix when planning work, making approvals and handling cyber incidents. The main aim is to make sure everyone knows their responsibility, especially when dealing with urgent issues.

1. What the letters mean

Responsible (R): The person or team that carries out the actual work. There can be more than one Responsible person.

Accountable (A): The person who owns the final outcome and gives the final approval. There should only be one Accountable role for each activity.

Consulted (C): People who must be asked for their views before a decision is made. Their input should be considered before moving forward.

Informed (I): People who need to be updated after a decision has been made. They do not take part in the decision.

2. Using the Matrix for Planning and Approvals

Before starting an activity in the RACI matrix, staff should identify who is Accountable and confirm the approval process. This prevents delays caused by finding out too late who should have approved the work.

Anyone listed as Consulted should be involved early enough for their advice to make a difference. If an activity is not included in the matrix, staff should raise it with the Steering Committee instead of assuming that no approval is needed.

3. Using the Matrix During a Cyber Incident

During a cyber incident, the Accountable person makes the final decision while the Responsible team carries out the required actions. Consulted roles provide advice, but decisions should not be delayed while waiting for everyone to agree.

If the incident meets the organisation's definition of a material incident, staff should also check the escalation thresholds to identify whether the issue needs to move to a higher level of management. The RACI matrix and escalation process should be used together.

Most importantly, unclear responsibilities should not delay efforts to contain an incident. The priority during the early stages should be to control the incident quickly and then clarify or document any role issues afterwards.

4. Handling Conflicts or Gaps

If the RACI matrix creates a conflict, such as one person being responsible for proposing and approving the same decision, the issue should be reported to the Steering Committee rather than handled informally.

The RACI matrix should be reviewed at least once a year. It should also be reviewed after a major incident if the incident shows that responsibilities or decision-making were unclear.

8. Task 5 Cyber-Risk Escalation and Segregation of Duties (20 marks)

TechGlobal needs a consistent method for deciding when a cyber-risk issue must move beyond operational management and who is authorised to accept, defer or escalate that risk.

- Design a major cyber-risk escalation workflow beginning with operational detection or identification and ending with the appropriate executive or Board decision.
- Define at least three escalation levels (for example Operational, Executive and Board / Material Risk) and the criteria that trigger each level.
- Identify at least five segregation-of-duties or accountability weaknesses that could exist in TechGlobal's current IT-centric model.
- For each weakness, recommend a governance or control measure that reduces the conflict without creating unnecessary bureaucracy.
- Explain how significant decisions will be recorded, tracked, reviewed and closed so that TechGlobal has an auditable decision trail.

Required Evidence Task 5

- Major Cyber-Risk Escalation Workflow.
- Escalation threshold table.

- Segregation-of-Duties / Accountability Weakness Register with at least five issues and recommended controls.
- Short decision-recording and assurance note.

Risk Escalation Threshold

Level	Example Trigger	Decision Authority	Required Notification	Target Response Time
Level 1 – Operational	Anomaly flagged by SOC/IT monitoring, single-BU impact, cost under \$25,000; no data exposed	IT/SOC Lead	Inform CISO	Triage within 4 hours; contain within 24 hours
Level 2 – Executive	Confirmed data exposure (employee/limited customer data) cost \$25,000–\$250,000; 2+ business units affected; possible regulatory angle	CISO, with CEO and Legal	Inform Executive Security Council	Materiality assessed within 24 hours; CEO briefed within 48 hours
Level 3 – Material / Board	Regulated data exposed at scale cost over \$250,000; enterprise-wide impact; confirmed regulatory notification obligation	Board Risk Committee	Inform full Board; Legal confirms external disclosure position	Board notified within 24–72 hours (ahead of statutory notification deadlines)

Segregation-of-Duties Weakness Register

ID	Process Area	Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk / Review
1	Security control implementation	IT Director both implements and approves security controls	Controls can be quietly deferred with no independent check	IT Director / CISO (proposed)	Logged, time-boxed CISO sign-off required for any control exception	Low — review at next Steering Committee cycle
2	Privileged access management	Same team administers and audits privileged access	Inappropriate access goes undetected	IT	Independent quarterly access review by a party outside the	Medium — review quarterly with audit findings

					administering team	
3	Security budget approval	CISO proposes and would benefit from own budget requests	Spending decisions lack independent challenge	CISO / Finance	Material budget requests routed through joint Finance + CRO review before approval	Low — review annually at budget cycle
4	Business unit security exceptions	BU leaders grant local security exceptions without central visibility	Inconsistent risk posture across 5 offices	Business Unit Leaders	All exceptions logged centrally and reviewed monthly by Steering Committee	Medium — review monthly
5	Incident response	Incident responders both contain incidents and assess their own severity classification	Severity may be understated to avoid escalation scrutiny	IT/SOC	Severity classification ratified by CISO, not left solely to first responder	Low — review after each incident post-mortem

Decision-Recording / Assurance Note

All escalation decisions and exceptions to the separation of duties (SoD) should be recorded in the Steering Committee decision log. The record should include the date, person responsible for the decision, reason for the decision, any controls put in place to reduce the risk, and the date for review. Keeping these records provides clear evidence of how important security and risk decisions were made. It also shows that risks were identified and formally accepted rather than ignored, which can be useful during audits or regulatory reviews after an incident.

Appendix A Stakeholder Map Template

Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution

Appendix B Governance Responsibility Matrix Template

Role	Purpose	Core Responsibilities	Decision Authority	Reports / Escalates To	KPIs / Evidence
Board					
CEO					
CISO					
CRO / Risk					
Legal					
Finance					
HR					
IT					

Appendix C RACI Matrix Template

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU Leader
Cybersecurity strategy approval									
Security policy approval									
Enterprise cyber-risk assessment									
Risk acceptance									
Security budget approval									
Security architecture approval									
Third-party security review									
Access governance									
Incident response governance									

Material incident escalation									
Regulatory notification decision									
Security awareness programme									
Vulnerability remediation oversight									
Business continuity / recovery governance									
Board cyber-risk reporting									

Appendix D Security Governance Committee Decision Log

Date	Decision / Issue	Decision Owner	Decision	Rationale	Actions / Owner	Review Date

Appendix E Risk Escalation Threshold Template

Level	Example Trigger	Decision Authority	Required Notification	Target Response Time
Level 1 – Operational				
Level 2 – Executive				
Level 3 – Material / Board				

Appendix F Segregation-of-Duties Weakness Register

ID		Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk / Review
1						
2						
3						
4						
5						